

# ROYAL HOSPITAL

## Patient Phishing Awareness Campaign

Usable Cybersecurity Module | NHS DSPT v6.0 · NCSC Guidance · UK GDPR · ISO 27001:2022

### 1.0. INTRODUCTION

Hospital patients are a high-value target for cybercriminals yet receive little to no security awareness training. Unlike clinical staff, patients interact with NHS digital systems; appointment portals, the NHS App, online registration which are outside any organisational security perimeter, with no policy framework, no incident channel, and no baseline training. Royal Hospital (RH) patients access these services through the RH website and extranet-facing systems, creating direct external attack surface.

This report presents a phishing simulation storyboard campaign targeting RH patients across three attack vectors: email phishing, SMS smishing, and voice phishing (vishing). The campaign is grounded in behavioural theory and experiential learning, and aligned with NCSC guidance, UK GDPR, and the NHS DSPT.

### 1.1. USER GROUP ANALYSIS & SECURITY CHALLENGES

#### 1.1.1. User Group Selection: Patients

Patients are selected because they combine maximum digital exposure with minimum security preparation. Action Fraud reported a 67% rise in NHS-branded phishing attacks targeting patients in 2022–23 [1]. Patient vulnerability arises from three factors: health anxiety that attackers exploit to induce urgency ("your appointment will be cancelled"); high trust in NHS branding that reduces critical scrutiny; and limited familiarity with digital threat indicators such as domain spoofing. A compromised patient account exposes NHS numbers, dates of birth, addresses, and medication data; information enabling identity fraud, prescription redirection, and downstream attacks on RH systems [2].

#### 1.1.2. Security Challenges and Threat Landscape

| Attack Vector   | Patient Impact                                                    | Framework Ref.                       | Root Cause                                                     |
|-----------------|-------------------------------------------------------------------|--------------------------------------|----------------------------------------------------------------|
| Email Phishing  | Credential theft; identity fraud                                  | NCSC 10 Steps; UK GDPR Art.5(1)(f)   | NHS branding trust; urgency bias; appointment anxiety [3]      |
| Smishing (SMS)  | Payment fraud; malware installation                               | NHS DSPT Standard 9; ISO 27001 A.6.3 | High SMS trust; limited link-inspection literacy [1]           |
| Vishing (Voice) | NHS number and personal data harvested for medical identity theft | ISO 27001 A.6.3; ICO Enforcement     | Authority deference; absence of caller-verification habits [4] |

Patient non-compliance with safe digital behaviour mirrors Cialdini's [4] influence framework: authority (NHS branding), urgency (appointment deadlines), and scarcity (limited appointment

slots) are systematically weaponised. Unlike clinical staff, patients cannot be reached through policy mandates, awareness must be delivered through accessible public channels that match their digital context.

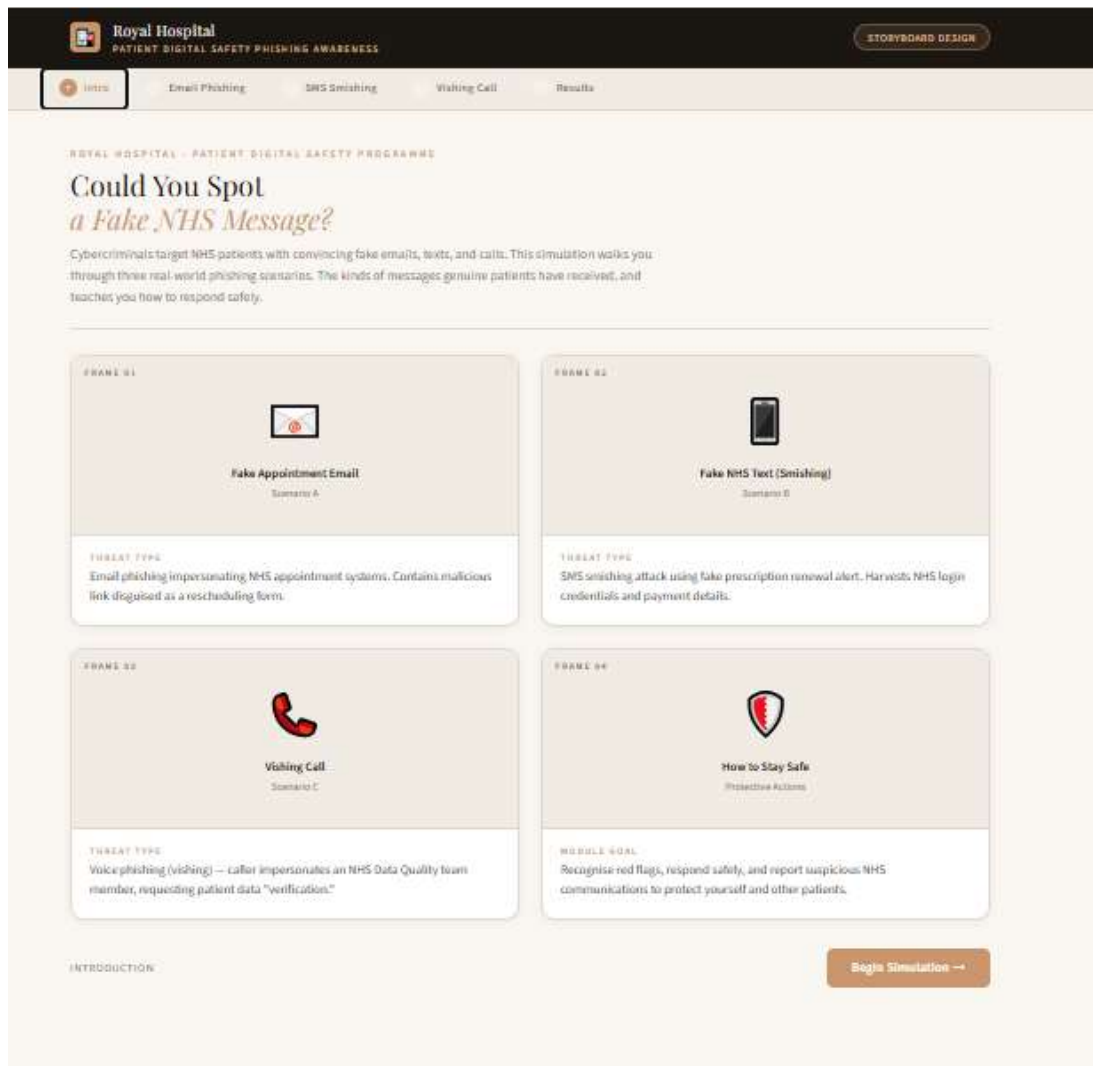
## **2.0. CAMPAIGN DESIGN**

### **2.1. Primary Artefact: Phishing Simulation Storyboard**

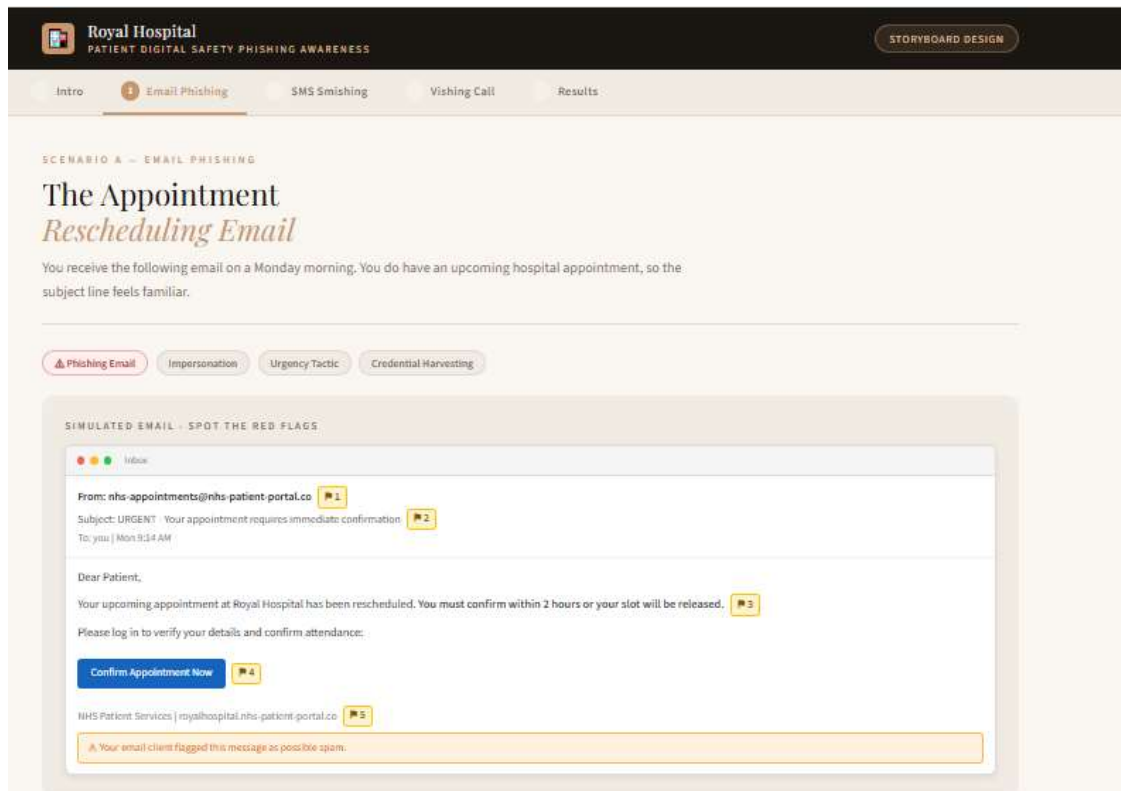
The primary artefact is a browser-based interactive phishing simulation storyboard (HTML5, no login required) presenting three scenarios; email phishing, smishing, and vishing, each featuring a realistic attack reproduction, annotated red flags, a decision prompt, and immediate feedback. The storyboard applies Kolb's experiential learning cycle [5]: patients experience a convincing simulated attack, reflect on what made it persuasive, learn the underlying principles, and practise safe responses. Patients who choose the wrong option receive a non-punitive explanation rather than a warning, removing the shame that Kirlappos and Sasse [6] identify as the primary inhibitor of reporting.

### **2.2. Scenario Design**

- **Storyboard Intro** – A brief introduction to the whole storyboard and scenarios covered



- **Scenario A - Email Phishing:** Fake appointment rescheduling email with urgency cues and spoofed NHS domain. Five annotated red flags teach domain verification and safe verification routes via nhs.uk.



- **Scenario B - Smishing:** Fake prescription renewal text with payment link. Establishes that NHS charges are never collected via SMS and introduces the NHS App as the safe alternative.

**Royal Hospital**  
PATIENT DIGITAL SAFETY PHISHING AWARENESS

STORYBOARD DESIGN

Intro

Email Phishing

**SMS Smishing**

Vishing Call

Results

SCENARIO B — SMS SMISHING

# The Prescription

## Renewal Text

You receive a text message on your phone. You do take regular medication, so a prescription reminder seems plausible.

SmsSmishing (SMS Phishing)

Credential Theft

Payment Fraud

SMULATED SMS — SPOT THE RED FLAG

Message

NHS-Renewal

Your NHS prescription is expiring. Renew now to avoid a £3.50 charge. Confirm details: [Click to renew your health](#)

RED FLAG — SENDER NAME

"NHS-Renewal" is not an official NHS sender ID. The NHS uses NHSApp or your GP practice name for legitimate SMS.

RED FLAG — FAKE DOMAIN

"nhs-rs-renew.com" is not an NHS domain. All genuine NHS digital services use nhs.uk addresses only.

RED FLAG — PRESCRIPTION CHARGE

NHS prescription charges (£9.95) are never collected via text message links. Charges are paid at your pharmacy.

WHAT A REAL NHS TEXT LOOKS LIKE

Genuine NHS texts contain your name, come from your GP surgery, and never ask you to click a link to pay or confirm personal details.

**Your Decision**  
You rely on your prescription. What do you do?

The text mentions a fee you recognise. How do you respond?

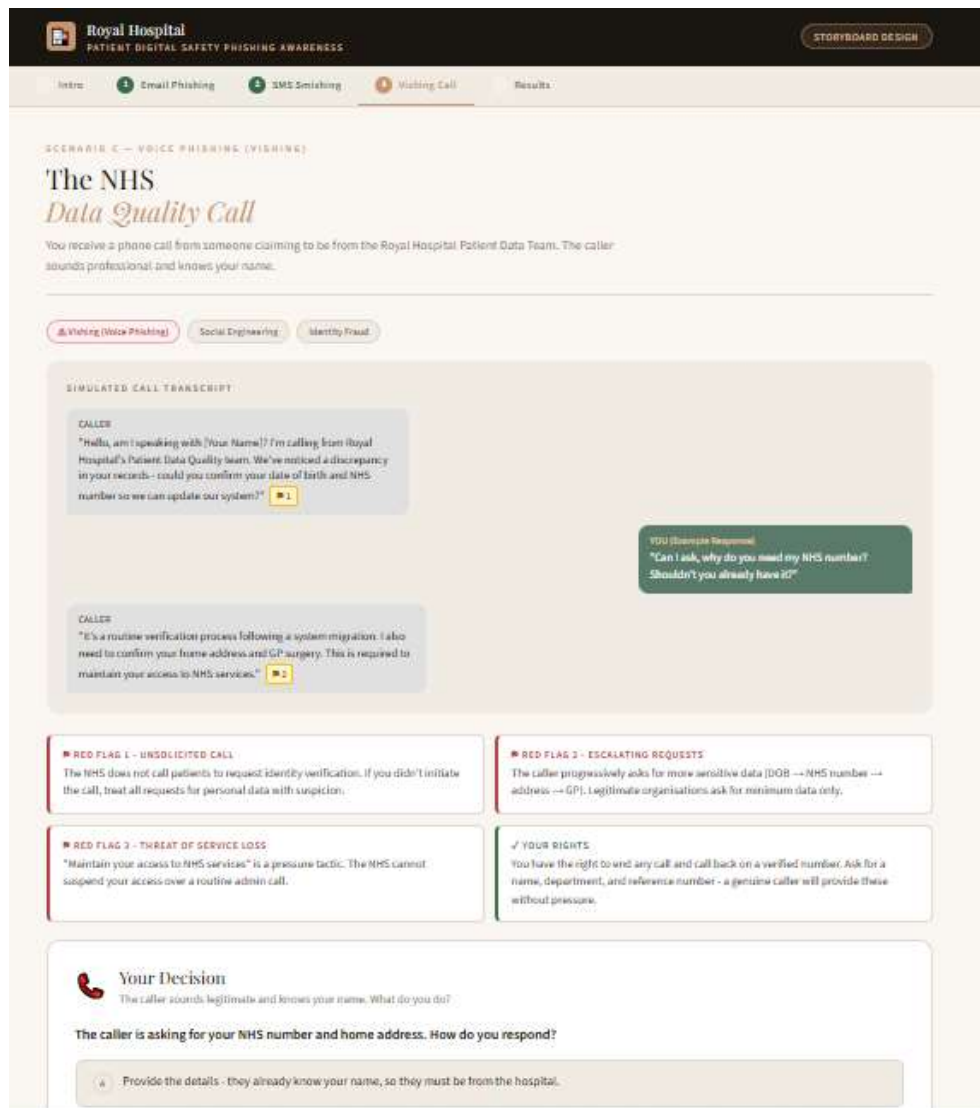
A Click the link to check — you don't want your prescription to lapse.

B Reply "STOP" to unsubscribe from the messages.

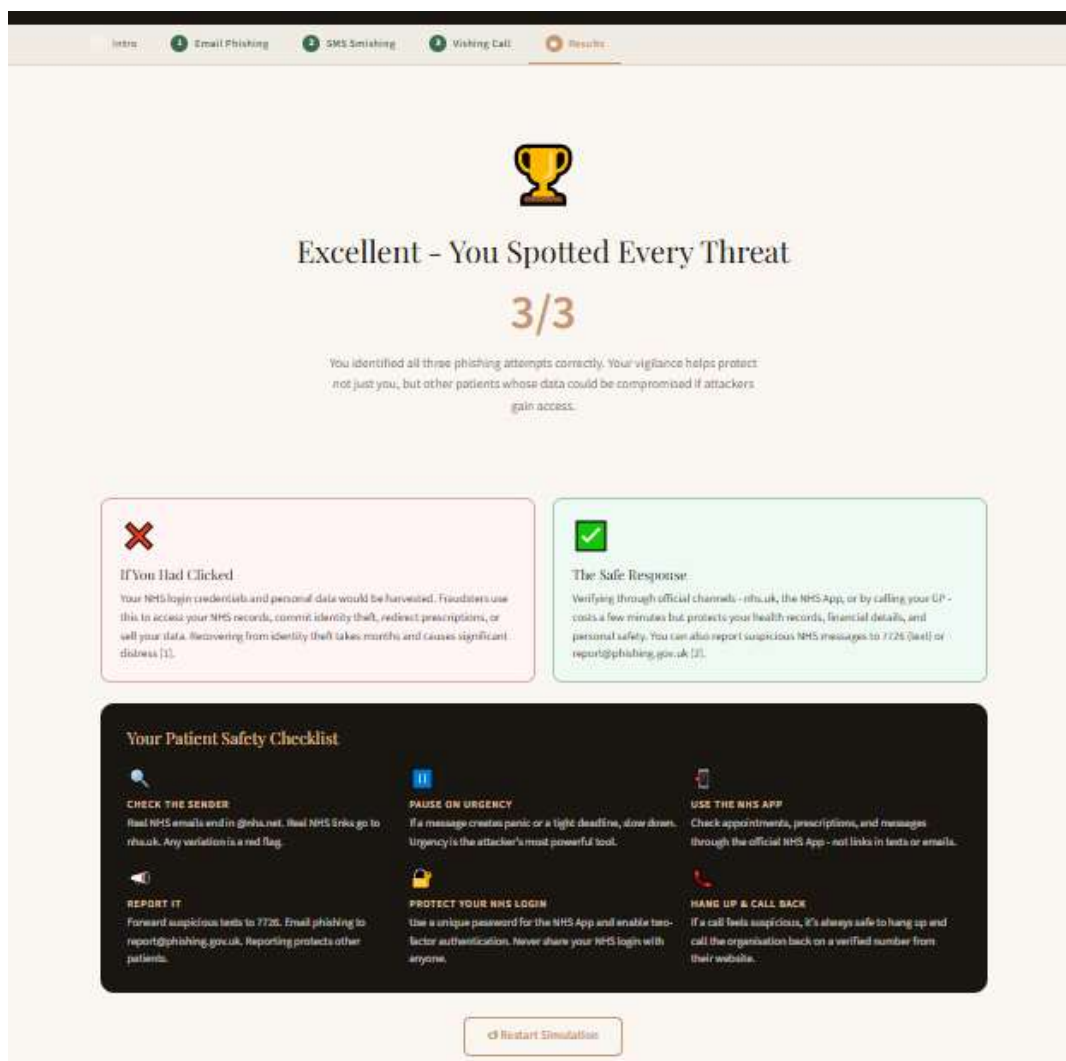
C Ignore the text. Contact your GP surgery directly using the number on your prescription bag or the NHS App to check your prescription status.

D Call the number on the text message to query it.

- **Scenario C - Vishing:** Caller impersonating NHS Data Team requests NHS number and address. Teaches hang-up-and-call-back on a verified number as the standard safe response.



- The Result: The overview and feedback from the simulation



### 2.3. Support Elements

| Element                   | Description                                                                        | Threat Addressed         |
|---------------------------|------------------------------------------------------------------------------------|--------------------------|
| Waiting Room Poster       | A3 poster: '3 Signs It's Not the NHS' — displayed across all RH waiting areas      | All three vectors        |
| Appointment Letter Insert | QR code to simulation included in all RH appointment confirmation letters          | Email phishing, smishing |
| NHS App Notification      | Push notification linking to simulation during NHS Cyber Awareness Month (October) | All three vectors        |

### 2.4. Measurable Outcomes – Kirkpatrick Evaluation [7]

| Level | Type     | Metric                                               | Target                  |
|-------|----------|------------------------------------------------------|-------------------------|
| 1     | Reaction | Post-simulation satisfaction survey (5-point Likert) | Mean $\geq 4.0/5.0$     |
| 2     | Learning | Correct decisions per scenario (pre/post retest)     | $\geq 25\%$ improvement |

|   |           |                                                           |                                 |
|---|-----------|-----------------------------------------------------------|---------------------------------|
| 3 | Behaviour | Patient phishing reports to 7726 / report@phishing.gov.uk | Measurable increase at 6 months |
| 4 | Results   | Patient-linked credential breach incidents at RH          | Reduction; DSPT Standard 9 met  |

### 3.0. CONCLUSION AND REFLWCTION

#### 3.1. Rationale for Design Decisions

The storyboard format was selected because patients cannot be reached through policy mandates, engagement must be voluntary and contextually embedded. Presenting patients with a realistic simulated attack before revealing it as training applies the teachable moment principle [8]: the emotional near-miss creates deeper memory encoding than passive instruction. Each scenario uses NHS contexts patients personally recognise (appointment anxiety, prescription management), maximising relevance and transfer to real-world behaviour. The artefact is mobile-responsive, requires no account, and completes in under ten minutes, minimising time burden for patients already attending hospital.

#### 3.2. Avoiding Burden and Addressing Root Causes

The campaign targets the root cause: contextual unawareness, rather than blaming individuals. Wrong answers receive constructive feedback, not warnings, reflecting Adams and Sasse's [9] finding that blame-based security messaging suppresses reporting. A complementary printed leaflet will address digital exclusion among older and lower-literacy patient populations, ensuring equitable reach.

#### 3.3. Strategic Alignment

The campaign satisfies NHS DSPT Standard 9 (awareness for all who access NHS data), ISO 27001:2022 A.6.3 (security education for relevant external parties), and UK GDPR Article 5(1)(f) (organisational duty of confidentiality). Effectiveness will be reviewed at 6 and 12 months using the Kirkpatrick metrics above, with scenario content refreshed quarterly to reflect evolving attack methods.



## REFERENCES

- [1] Action Fraud, 'NHS Fraud and Cybercrime Report 2022–23,' National Fraud Intelligence Bureau, London, 2023.
- [2] Trustwave, 'Healthcare Threat Intelligence Report 2023,' Trustwave SpiderLabs, Chicago, IL, 2023.
- [3] R. B. Cialdini, *Influence: Science and Practice*, 5th ed. Allyn & Bacon, Boston, MA, 2001.
- [4] M. Workman, 'Wisecrackers: A theory-grounded investigation of phishing,' *J. Amer. Soc. Inf. Sci. Technol.*, vol. 59, no. 4, pp. 662–674, 2008.
- [5] D. A. Kolb, *Experiential Learning: Experience as the Source of Learning and Development*. Prentice Hall, Englewood Cliffs, NJ, 1984.
- [6] I. Kirlappos and M. A. Sasse, 'Security education against phishing: A modest proposal for a major rethink,' *IEEE Security & Privacy*, vol. 10, no. 2, pp. 24–32, 2012.
- [7] D. L. Kirkpatrick, *Evaluating Training Programs: The Four Levels*, 3rd ed. Berrett-Koehler, San Francisco, CA, 2006.
- [8] K. Glanz, B. K. Rimer, and K. Viswanath, Eds., *Health Behavior: Theory, Research, and Practice*, 5th ed. Jossey-Bass, San Francisco, CA, 2015.
- [9] A. Adams and M. A. Sasse, 'Users are not the enemy,' *Commun. ACM*, vol. 42, no. 12, pp. 40–46, 1999.
- [10] NHS England, 'Data Security and Protection Toolkit,' v6.0, NHS Digital, 2023.
- [11] ISO/IEC 27001:2022, *Information Security Management Systems — Requirements*. ISO, Geneva, 2022.
- [12] NCSC, 'Security Awareness and Training: A Good Practice Guide,' NCSC, London, 2021.